DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

Team ID: SWTID-2026-4851

Project Title:

DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

Program: Naan Mudhalvan

Course : Cyber Security

Institution : Sree Narayana Guru College,Coimbatore (Bru36)

List of teammates

S.no	Name	Contact
1	Akash kevin H	akashakash2962006@gmail.com
2	Adithyan K	adhithyanadhiyan2002@gmail.com
3	Muhammed Amalshah V	amalsha024@gmail.com
4	Ranjani R	ranjanirajan58@gmail.com
5	Yadhu krishna M	yk7619138@gmail.com

PROJECT DETAILS:

TITLE :

DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

INTRODUCTION:

The modern digital era, driven by cloud services, remote work, and mobile devices, has rendered traditional, network-based security models insufficient. These older models can no longer protect sensitive information from advanced threats exploiting weak authentication and compromised devices. This has created a critical need for more intelligent, adaptive security mechanisms.

Context-aware access control (CAAC) addresses this by dynamically evaluating multiple factors including user identity, device security posture, geographic location, and application risk before granting access. This allows the system to make real-time decisions to permit, restrict, or block access.

The primary goal of this project is to design and implement a CAAC system that evaluates these parameters to enforce security actions, such as granting full access, requiring Multi-Factor Authentication (MFA), or denying access completely. This approach will reduce unauthorized access, protect sensitive data, and establish a flexible, intelligent security architecture for the modern digital workplace.

ABSTRACT:

The rapid adoption of cloud services, mobile devices, and hybrid work environments has significantly changed the traditional approach to network security. Conventional access control models that rely on fixed network perimeters and simple authentication mechanisms are no longer effective in protecting organizational resources. Modern organizations face an expanding attack surface where threats can originate from compromised devices, insecure networks, or unauthorized users. As a result, there is a growing need for intelligent and adaptive security systems that can evaluate access requests based on multiple contextual factors rather than relying solely on static authentication methods.

This project titled Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk,aims to develop a dynamic access control framework that improves security in distributed digital environments. The proposed system analyzes several contextual signals, including the user's identity and role, the security status of the device being used, the geographic location of the access request, and the risk level of the application being accessed. By integrating these factors, the system calculates a real-time risk score for every access attempt and applies appropriate security policies.

Based on the evaluated context, the system can make intelligent access decisions such as granting full access, restricting certain actions, requiring additional authentication through multi-factor authentication (MFA), or completely denying access. This approach enables organizations to enforce more granular and adaptive security controls that respond to the level of risk associated with each request.

The expected outcome of this project is a robust and flexible security model that reduces the risk of unauthorized access, protects sensitive organizational data, and minimizes the impact of credential compromise. At the same time, the system ensures a smooth and efficient user experience for trusted users operating in secure environments. By adopting a context-aware access control approach, organizations can establish a stronger security framework that supports safe and productive access to resources in today's highly dynamic and perimeter-less digital landscape.

Use Case Scenarios :

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA). ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (antivirus active, disk encryption enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

- User authenticated and authorized based on identity and group membership
- Direct micro-tunnel established specifically to the ERP application
- All other internal applications and network segments remain invisible and inaccessible

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled). ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

- Time-bound and role-specific access enforced
- Contractor restricted to a single application (Git repository)
- Lateral movement to adjacent systems completely blocked

Scenario 3: Executive Access to Sensitive Financial Documents

A company VP needs to access a folder containing confidential M&A documents stored in a corporate SharePoint site. The user connects from a hotel business center while traveling internationally, using their company-managed tablet. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, executive group membership, and device posture (which is compliant). However, the geolocation (unusual foreign country) and the application risk (highly sensitive document repository) trigger an elevated risk score. The policy engine grants access to the SharePoint site, but enforces additional restrictions: download and print capabilities are disabled, and the session is monitored for unusual behavior (e.g., mass download attempts). An alert is also sent to the security team for high-risk executive login.

Output:

- User authenticated with MFA and device compliant, but flagged for unusual location
- Read-only access granted with download/print restrictions enforced
- Security team alerted to potential credential misuse or espionage attempt

Scenario 4: Remote Support Technician Access to Internal Tools

An IT support technician needs to access the corporate ServiceNow instance and a remote desktop tool to assist an employee. The technician connects from their home office using a company-managed desktop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (IT_Support), device posture (fully compliant), and connection type (home office, which is whitelisted for IT staff). Because the user, device, and location all meet the baseline, the policy engine grants direct micro-tunnel access to both ServiceNow and the specific remote desktop jump host used for employee support. The technician can perform their duties efficiently, but still has no access to finance systems, HR databases, or source code repositories.

Output:

- User authenticated and fully authorized based on trusted context
- Direct micro-tunnels established to ServiceNow and the remote desktop jump host
- Least-privilege access maintained; unrelated internal systems remain invisible

Scenario 5: High-Risk Application Access from a Low-Trust Location

A marketing coordinator needs to access the corporate Salesforce instance to update a campaign. The user connects from a coffee shop using their company-managed smartphone. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (Marketing_Salesforce_Users), device posture (managed and compliant), but flags the public Wi-Fi network as a high-risk connection. The policy engine determines that while the user and device are trusted, the network environment introduces unacceptable risk for direct access to a customer-facing CRM containing sensitive lead data. Instead of blocking access entirely, the user is routed through a secure ZPA browser isolation service, rendering the Salesforce session in a disposable container that prevents any data from persisting on the device or being exposed to the public network..

Output:

- User authenticated and device compliant, but network location deemed high-risk
- Access granted via browser isolation to prevent data leakage on public Wi-Fi
- Session is rendered in a secure container with copy/paste and download controls enforced

Stage – 1

Title: OWASP TO 10

Overview:

The **OWASP Top 10 (2025)** is a widely recognized list published by the OWASP Foundation that identifies the most critical security risks affecting modern web applications. It serves as an important guideline for developers, security professionals, and organizations to understand common vulnerabilities and improve application security. The list is developed based on real-world data, security research, and expert analysis from the global cybersecurity community. The **OWASP Top 10:2025** highlights major risks such as broken access control, security misconfiguration, software supply chain failures, cryptographic failures, injection attacks, insecure design, authentication failures, software and data integrity failures, logging and monitoring failures, and improper handling of exceptional conditions. These vulnerabilities represent the most common weaknesses exploited by attackers to compromise applications and sensitive data. By understanding and addressing the OWASP Top 10 risks, organizations can implement stronger security practices, improve secure coding standards, and reduce the likelihood of cyberattacks and data breaches in modern digital systems.

List of Vulnerability Table :

S.no	Vulnerability Name	CWE/CVE - No
1	Absolute Path Traversal	CWE-36
2	ASP.NET Misconfiguration: Password in Configuration File	CWE-13
3	Use of Unmaintained Third Party Components	CWE-1104
4	Cleartext Transmission of Sensitive Information	CWE-319
5	Improper Neutralization of Equivalent Special Elements	CWE-76
6	Plaintext Storage of a Password	CWE-256
7	Improper Authentication	CWE-287
8	Untrusted Search Path	CWE-426
9	Omission of Security-relevant Information	CWE-223
10	Unchecked Return Value	CWE-252

REPORT

Vulnerability Name:- Absolute Path Traversal

CWE/CVE : -CWE-36

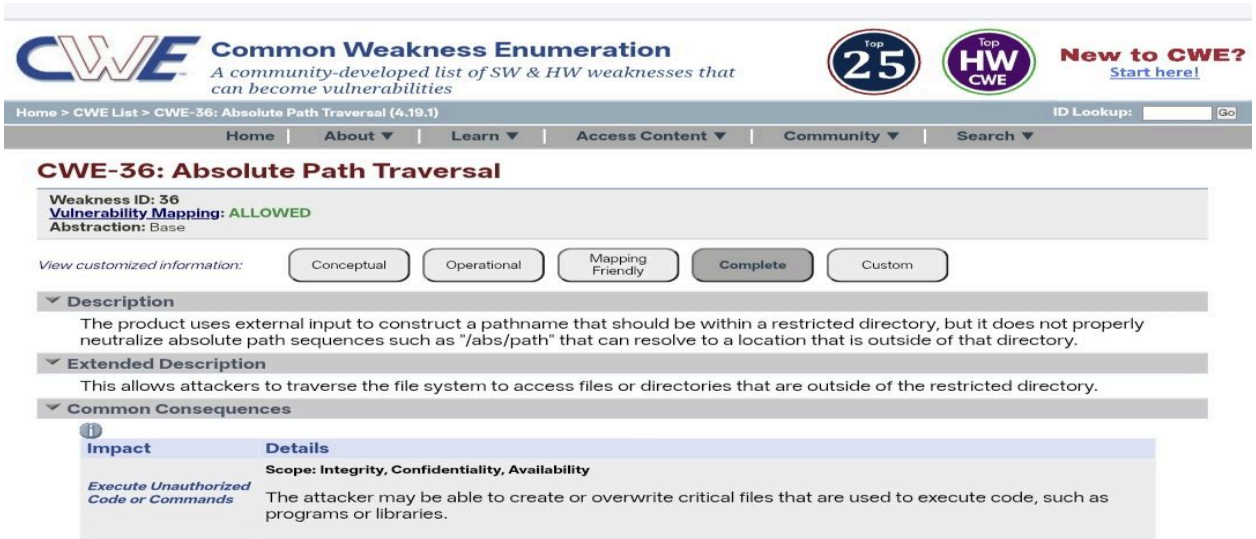
OWASP/SANS Category:-A01:2025 Broken Access Control

Description:-

Absolute Path Traversal is a vulnerability that allows attackers to access files and directories outside the intended folder of a web application. This occurs when user input used in file paths is not properly validated. By manipulating the file path, an attacker can access sensitive files such as system configurations, application code, or confidential data. Proper input validation and restricting file access can help prevent this vulnerability.

Business Impact::-

Absolute Path Traversal can have serious consequences for an organization. If exploited, attackers may gain unauthorized access to sensitive files such as system configurations, application source code, or confidential business data. This can lead to data breaches, exposure of internal information, system compromise, and loss of customer trust. In severe cases, it may also result in financial losses, legal penalties, and damage to the organization's reputation. Proper security controls and input validation are necessary to reduce this risk.



Vulnerability Name:- ASP.NET Misconfiguration: Password in Configuration File

CWE/CVE : CWE-13

OWASP/SANS Category: A02:2025 - Security Misconfiguration

Description:-

This vulnerability occurs when sensitive information such as passwords, database credentials, or API keys are stored in plain text within ASP.NET configuration files (e.g., web.config). If these configuration files are not properly secured, attackers may gain access to them through misconfigured servers, source code exposure, or unauthorized file access. Once obtained, these credentials can be used to access databases, internal systems, or other critical services

Business Impact:

Exposure of passwords in configuration files can lead to unauthorized access to critical systems and sensitive organizational data. Attackers may exploit the exposed credentials to compromise databases, manipulate application data, or gain deeper access to the internal network. This can result in data breaches, financial losses, service disruption, legal consequences, and significant damage to the organization's reputation and customer trust.

Vulnerability Name:-Use of Unmaintained Third Party Components

CWE/CVE : CWE-1104

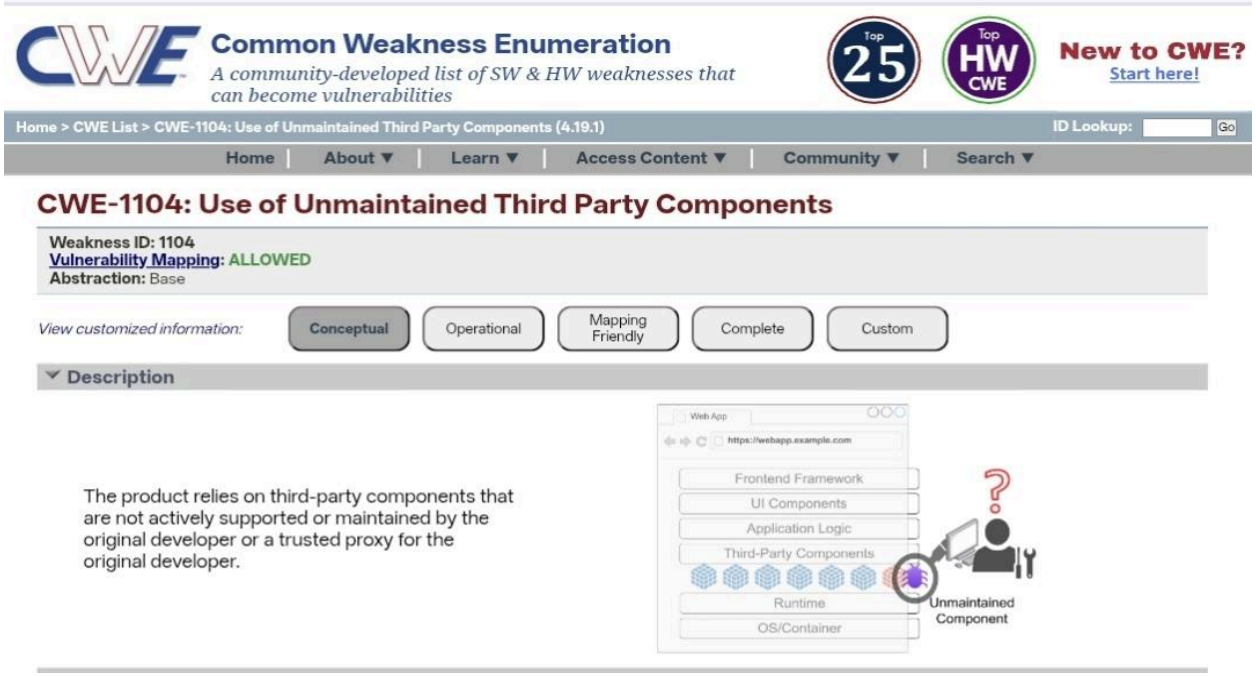
OWASP/SANS Category: A03:2025 - Software Supply Chain Failures

Description:-

This vulnerability occurs when an application uses third-party libraries, frameworks, or software components that are no longer maintained or updated by their developers. Unmaintained components may contain known security vulnerabilities that remain unpatched, making them an easy target for attackers. Since these components do not receive security updates or fixes, any existing weaknesses can be exploited to compromise the application.

Business Impact:

Using unmaintained third-party components can expose the application to serious security risks, including unauthorized access, data breaches, and system compromise. Attackers may exploit known vulnerabilities in outdated components to gain control of the system or access sensitive data. This can lead to financial losses, operational disruptions, legal issues, and damage to the organization's reputation and customer trust.



Vulnerability Name:- Cleartext Transmission of Sensitive Information

CWE/CVE : CWE-319

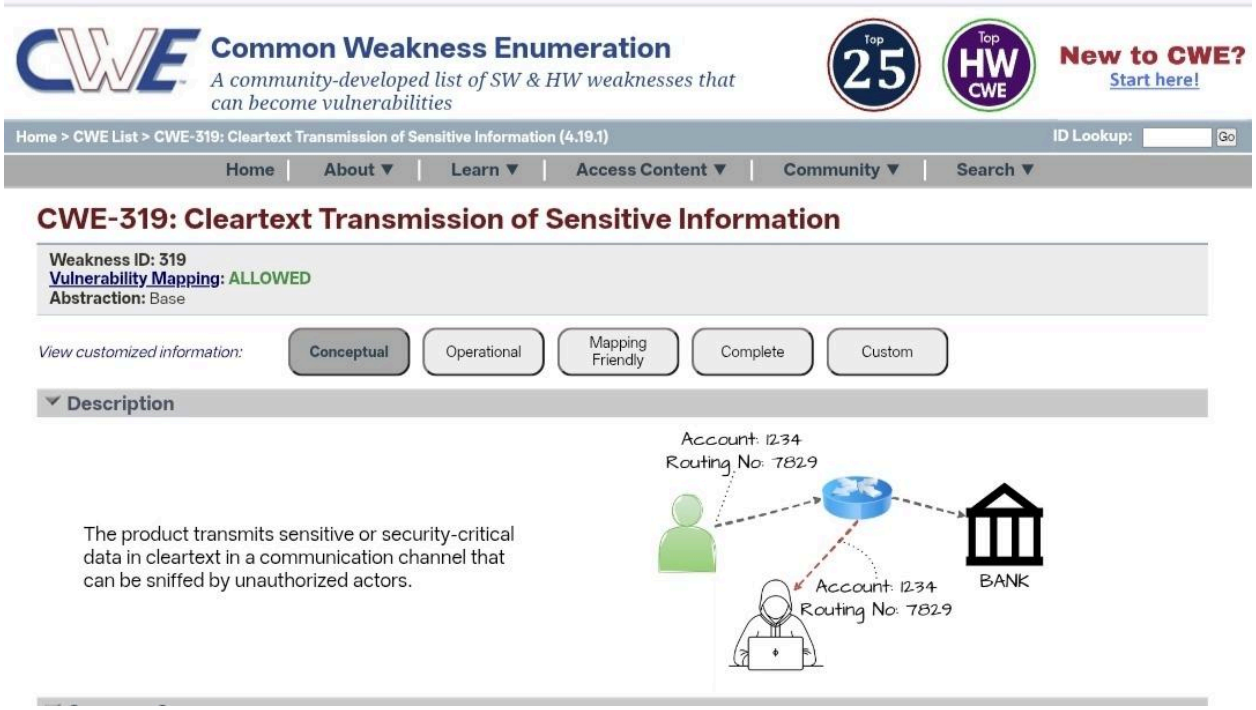
OWASP/SANS Category: A04:2025 - Cryptographic Failures

Description:-

This vulnerability occurs when sensitive information such as usernames, passwords, personal data, or financial details is transmitted over a network without encryption. When data is sent in cleartext, attackers can intercept and read the information using techniques such as network sniffing or man-in-the-middle attacks. This usually happens when secure communication protocols like HTTPS or encryption mechanisms are not properly implemented.

Business Impact:

Cleartext transmission of sensitive information can lead to unauthorized access to confidential data, account compromise, and data breaches. Attackers who intercept this information may misuse it for identity theft, financial fraud, or further system attacks. This can result in financial loss, legal penalties, regulatory violations, and significant damage to the organization's reputation and customer trust.



Vulnerability Name:-Improper Neutralization of Equivalent Special Elements

CWE/CVE : CWE-76

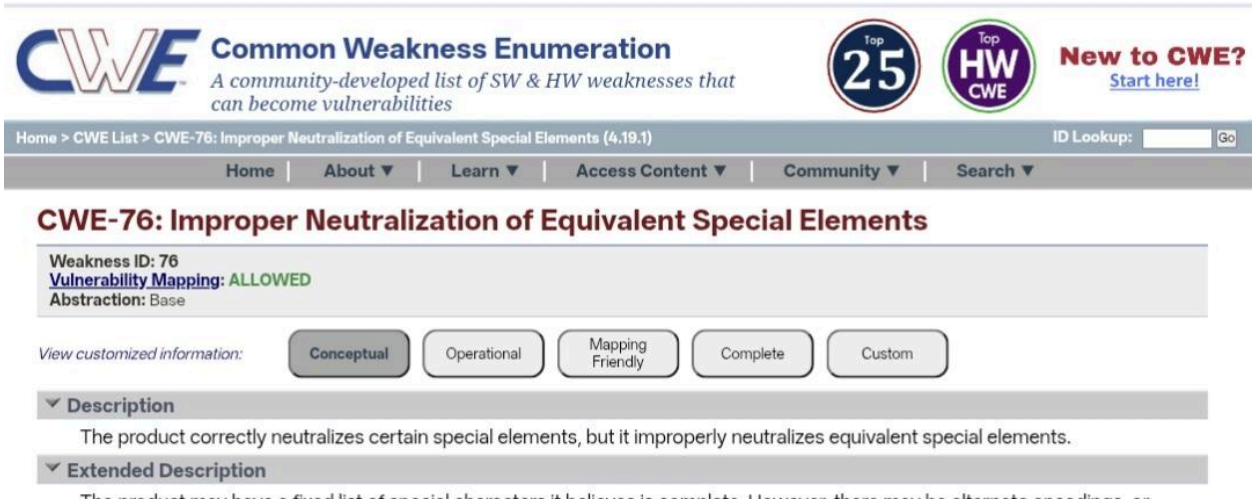
OWASP/SANS Category: A05:2025 - Injection

Description:-

This vulnerability occurs when a web application fails to properly validate or sanitize special characters or elements in user input. Attackers can exploit this weakness by inserting malicious code or unexpected input that the system interprets differently, leading to security issues such as injection attacks or unauthorized actions. Improper neutralization allows attackers to bypass security controls and manipulate the application's behavior.

Business Impact:

If exploited, this vulnerability can allow attackers to access sensitive information, modify application data, or execute unauthorized commands within the system. This may lead to data breaches, service disruption, and compromise of critical systems. As a result, organizations may experience financial losses, regulatory penalties, and damage to their reputation and customer trust.



Vulnerability Name:-Plaintext Storage of a Password

CWE/CVE : CWE-256

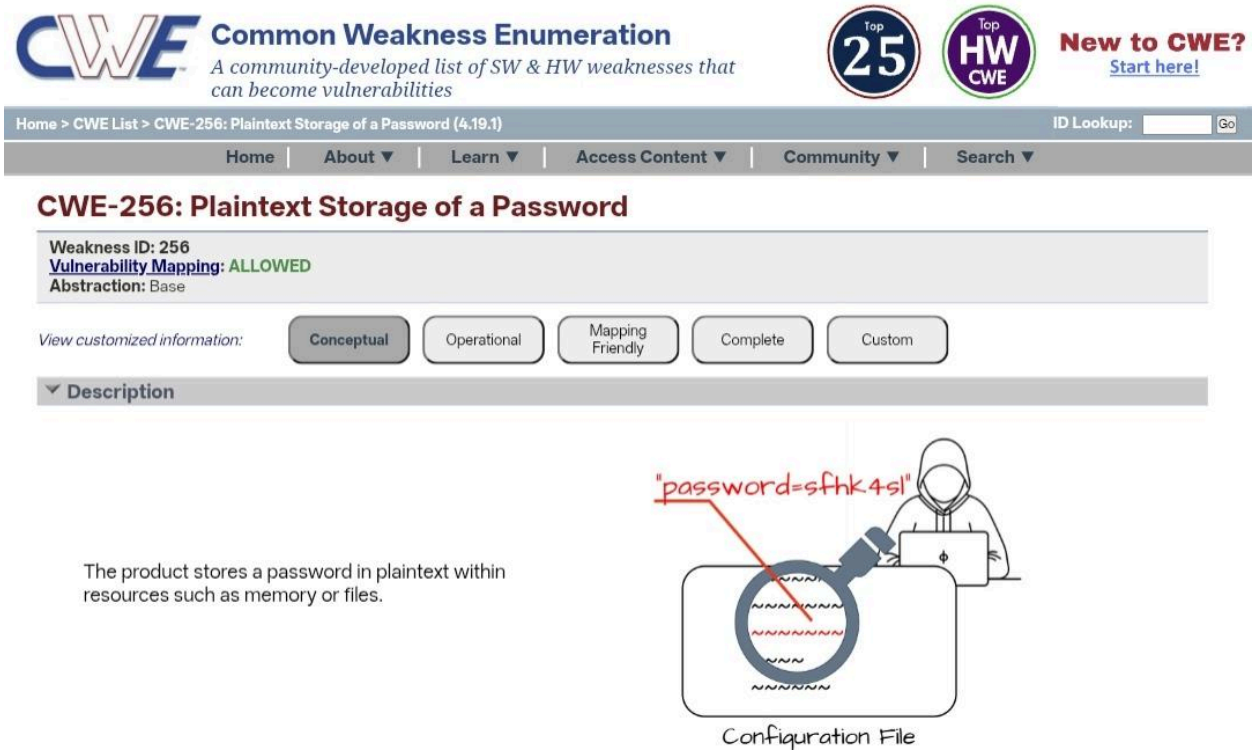
OWASP/SANS Category: A06:2025 - Insecure Design

Description:-

This vulnerability occurs when an application does not properly filter or handle special characters or encoded inputs provided by users. Attackers may use alternate representations (such as encoded or equivalent special elements) to bypass security filters and inject malicious input into the system. This weakness can allow attackers to manipulate application behavior, access restricted data, or perform unauthorized actions.

Business Impact:

Exploitation of this vulnerability can lead to unauthorized access to sensitive information, data manipulation, or execution of malicious commands within the application. This may result in data breaches, disruption of services, financial losses, and damage to the organization's reputation. Proper input validation and secure coding practices are essential to reduce this risk**.**



Vulnerability Name:-Improper Authentication

CWE/CVE : CWE-287

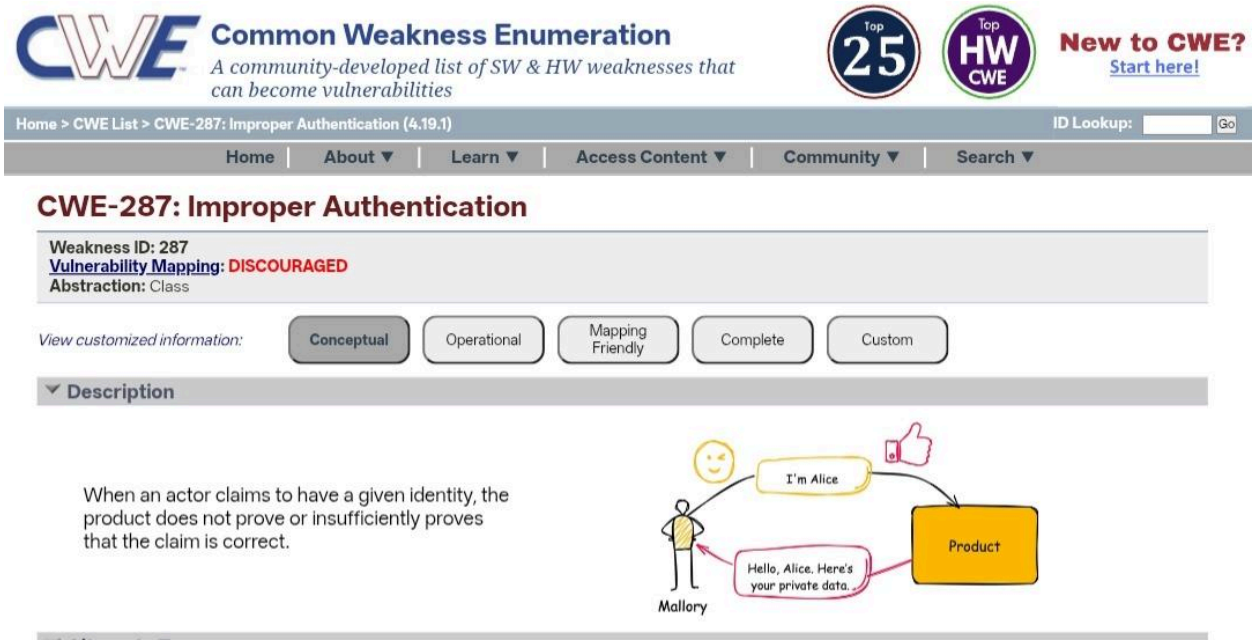
OWASP/SANS Category: A07:2025 - Authentication Failures

Description:-

Improper Authentication occurs when an application fails to correctly verify the identity of a user before granting access to system resources. This vulnerability may arise due to weak authentication mechanisms, poor session management, default credentials, or improper implementation of login controls. Attackers can exploit this weakness to bypass authentication processes and gain unauthorized access to user accounts or sensitive system functions.

Business Impact:

If exploited, improper authentication can allow attackers to access confidential information, perform unauthorized transactions, or take control of user accounts. This may lead to data breaches, financial losses, service disruptions, and misuse of organizational resources. In addition, such incidents can damage the organization's reputation, reduce customer trust, and potentially result in legal or regulatory consequences.



Vulnerability Name:- Untrusted Search Path

CWE/CVE : CWE-426

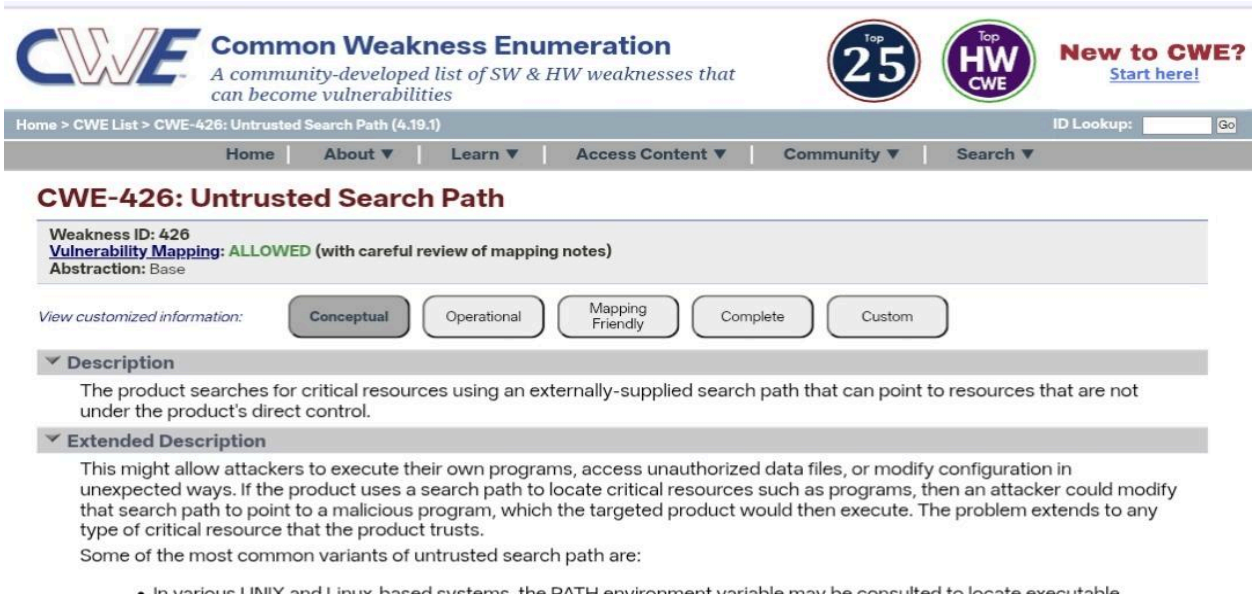
OWASP/SANS Category: A08:2025 - Software or Data Integrity Failures

Description:-

Untrusted Search Path is a vulnerability that occurs when an application loads external programs, libraries, or executable files from directories that are not trusted or properly secured. If the application does not specify a safe and fixed path for these files, attackers may place a malicious file in the search path. When the application runs, it may unknowingly execute the attacker's malicious file instead of the intended one.

Business Impact:

Exploitation of this vulnerability can allow attackers to execute malicious code within the system, potentially leading to system compromise, unauthorized access, or data manipulation. This can result in service disruption, data breaches, financial losses, and damage to the organization's reputation. Proper configuration and restricting execution paths can help prevent this risk.



CWE Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities
Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-426: Untrusted Search Path (4.19.1) ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-426: Untrusted Search Path

Weakness ID: 426
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product searches for critical resources using an externally-supplied search path that can point to resources that are not under the product's direct control.

Extended Description

This might allow attackers to execute their own programs, access unauthorized data files, or modify configuration in unexpected ways. If the product uses a search path to locate critical resources such as programs, then an attacker could modify that search path to point to a malicious program, which the targeted product would then execute. The problem extends to any type of critical resource that the product trusts.

Some of the most common variants of untrusted search path are:

- In various UNIX and Linux-based systems, the PATH environment variable may be consulted to locate executable

Vulnerability Name:- Omission of Security-relevant Information

CWE/CVE : CWE-223

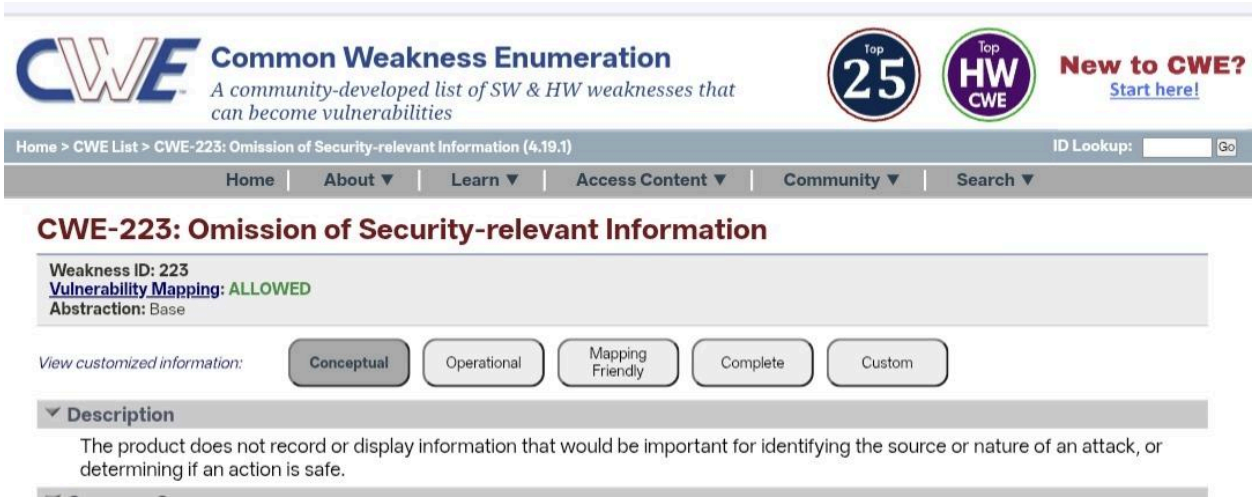
OWASP/SANS Category: A09:2025 - Security Logging and Alerting Failures

Description:-

Omission of Security-Relevant Information occurs when an application fails to record or provide important security-related details such as login attempts, access requests, errors, or suspicious activities. Without proper logging and monitoring, it becomes difficult to detect security incidents, investigate attacks, or respond to potential threats in a timely manner.

Business Impact:

If security-relevant information is not properly logged or monitored, organizations may be unable to identify unauthorized access, data breaches, or malicious activities within their systems. This can delay incident response, increase the impact of cyberattacks, and result in financial losses, regulatory penalties, and damage to the organization's reputation. Proper logging and monitoring practices are essential to maintain strong security visibility.



Vulnerability Name:-Unchecked Return Value

CWE/CVE : CWE-252

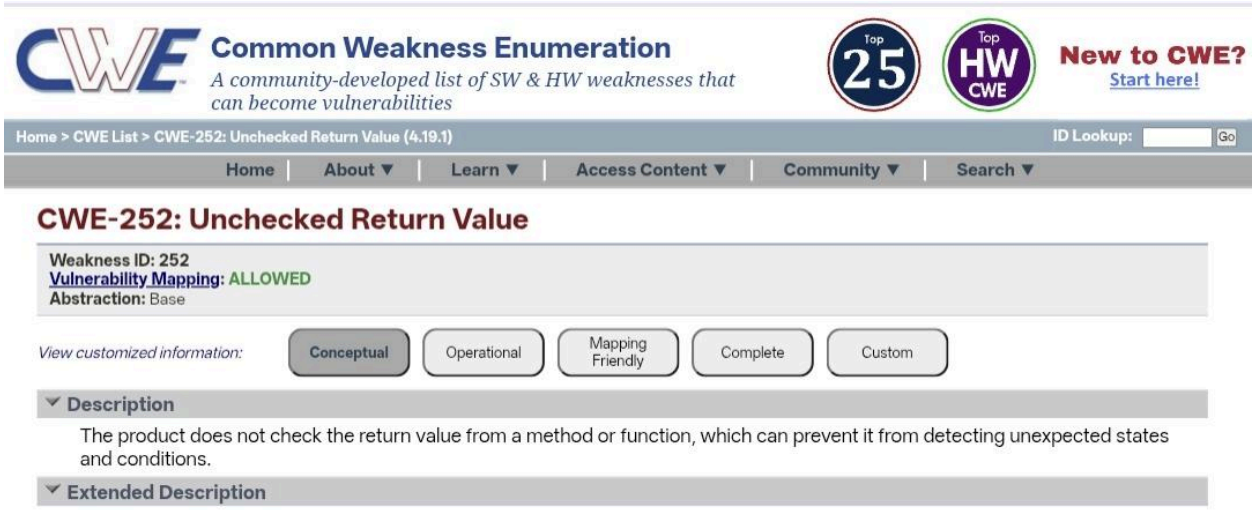
OWASP/SANS Category: A10:2025 - Mishandling of Exceptional Conditions

Description:-

Unchecked Return Value is a vulnerability that occurs when a program fails to verify the return value of a function or system call. Many functions return a value indicating whether an operation was successful or failed. If the application does not check these return values, it may continue execution even when an error has occurred. This can lead to unexpected behavior, security weaknesses, or system failures.

Business Impact:

Exploiting this vulnerability may allow attackers to trigger application errors, bypass security controls, or cause system instability. This can lead to data corruption, service disruptions, or unauthorized actions within the system. As a result, organizations may face operational issues, financial losses, and potential damage to their reputation.



Stage 2

Title: NESSUS SCAN

Overview:

A Nessus scan is a widely used vulnerability assessment process performed using Nessus vulnerability scanner, a security tool developed by Tenable. It is designed to identify security weaknesses, misconfigurations, and vulnerabilities in networks, systems, and applications. Nessus scans computers, servers, databases, and network devices to detect potential security risks that attackers could exploit. The tool compares system configurations and installed software against a large database of known vulnerabilities and security issues.

During a Nessus scan, the scanner performs various checks such as identifying open ports, outdated software versions, missing security patches, weak configurations, and known security vulnerabilities. After the scan is completed, it generates a detailed report that classifies vulnerabilities based on severity levels such as critical, high, medium, and low. This information helps security teams prioritize and fix vulnerabilities before they can be exploited by attackers. Overall, Nessus scanning plays an important role in maintaining a strong cybersecurity posture by helping organizations continuously monitor and improve the security of their IT infrastructure.

Sl.No	Vulnerability Name	Severity	Plugins
1	Nessus SYN scanner	port scanner	11219
2	Device Type	General	54615
3	Traceroute Information	General	10287
4	TLS Supported Groups	General	277654
5	OS Fingerprints Detected	General	209654

Report:

Vulnerability name: Nessus SYN scanner

Severity:port scanner

Plugin: 11219

Description:

The Nessus SYN Scanner is a scanning technique used during vulnerability assessments to identify open ports and services running on a target system. It works by sending TCP SYN packets to specific ports and analyzing the responses from the target host. If the port responds with a SYN-ACK, it indicates that the port is open and actively accepting connections. While this technique is commonly used for legitimate security testing, if detected on a network it may indicate that an attacker or unauthorized user is attempting to scan the system to discover open ports and potential entry points.

Solution:

To reduce the risk associated with SYN scanning, organizations should implement strong network security measures. This includes configuring firewalls to block or limit unnecessary ports, using intrusion detection or prevention systems (IDS/IPS) to detect scanning activities, and restricting network access to trusted users. Regular monitoring of network traffic and applying proper access control policies can also help identify and prevent unauthorized scanning attempts.

Business Impact:

If attackers perform SYN scans successfully, they may discover open ports and vulnerable services within the network. This information can be used to launch further attacks such as exploitation of vulnerabilities, unauthorized access, or denial-of-service attacks. As a result, organizations may face data breaches, service disruptions, financial losses, and damage to their reputation. Implementing proper network monitoring and security controls is essential to mitigate this risk.

Vulnerability name: Device Type
Severity: General
Plugin: 54615

Description:

The Device Type finding in a Nessus scan identifies the type of device present on the network, such as a server, workstation, router, firewall, or printer. This information is gathered during the scanning process to understand the nature of the target system and the services it may provide. Although this is mainly informational, it can reveal useful details about the network infrastructure that could potentially be used by attackers during reconnaissance.

Solution:

To reduce the risk associated with device information disclosure, organizations should limit unnecessary exposure of system information. Network administrators should configure firewalls, disable unnecessary services, and restrict access to sensitive network details. Regular

vulnerability scanning and network monitoring should also be implemented to ensure that system information is not easily exposed to unauthorized users.

Business Impact:

If attackers obtain information about device types within a network, they may use this information to identify potential targets and plan more focused attacks. Knowing the type of device and its role in the network can help attackers exploit specific vulnerabilities related to that device. This may increase the risk of unauthorized access, system compromise, or disruption of critical services within the organization.

Vulnerability name: Traceroute Information

Severity: General

Plugin:10287

Description:

Traceroute Information is a finding that reveals the network path taken by data packets from the scanning system to the target host. During a Nessus scan, the traceroute process identifies intermediate network devices such as routers and gateways between the source and destination. This information helps administrators understand network routing and connectivity. However, if exposed, it may reveal details about the internal network structure and routing paths.

Solution:

To reduce the exposure of traceroute information, organizations should configure firewalls and routers to restrict unnecessary network diagnostic responses. Disabling or limiting ICMP responses and controlling network visibility can help prevent external users from discovering internal network routes. Regular network monitoring and proper configuration of security devices can also minimize the risk of information disclosure.

Business Impact:

If attackers obtain traceroute information, they may gain insights into the network architecture, including intermediate devices and network paths. This information can assist attackers in

mapping the network, identifying critical infrastructure components, and planning targeted attacks. As a result, it may increase the risk of network intrusion, system compromise, or disruption of network services within the organization.

Vulnerability name:TLS Supported Groups
Severity: General
Plugin:277654

Description:
TLS Supported Groups refers to the list of cryptographic groups (such as elliptic curve groups) that a server supports for establishing secure TLS connections. During a Nessus scan, this information is identified to determine whether the server supports strong or weak cryptographic groups. If weak or outdated groups are enabled, attackers may exploit them to weaken the encryption used during secure communication.

Solution:
Organizations should configure servers to support only strong and secure TLS cryptographic groups and disable weak or outdated ones. Regular updates to TLS configurations, applying security patches, and following recommended cryptographic standards can help strengthen secure communications. Security teams should also perform regular vulnerability scans to ensure that only modern and secure encryption groups are enabled.

Business Impact:
If weak TLS supported groups are enabled, attackers may exploit them to compromise the encryption used in secure communications. This could lead to interception or decryption of sensitive information transmitted between users and servers. As a result, organizations may face risks such as data breaches, exposure of confidential information, and loss of customer trust.

Vulnerability name:OS Fingerprints Detected

Severity: General

Plugin:209654

Description:

OS Fingerprints Detected is a finding from a Nessus scan indicating that the operating system of the target device can be identified through network responses and system behavior. During the scanning process, Nessus analyzes network packets, service responses, and system characteristics to determine the probable operating system running on the host. Although this information is useful for system administration and vulnerability assessment, it can also reveal system details to potential attackers.

Solution:

To reduce the risk of OS fingerprinting, organizations should implement proper network security controls. This includes configuring firewalls to limit unnecessary responses, disabling unused services, and using intrusion detection or prevention systems (IDS/IPS) to detect scanning activities. Regular patching and system hardening can also help minimize identifiable system characteristics.

Business Impact:

If attackers can identify the operating system of a target system, they can use this information to search for specific vulnerabilities related to that OS. This may allow them to launch targeted attacks, exploit known weaknesses, or gain unauthorized access to the system. As a result, organizations may face security breaches, service disruptions, or compromise of critical systems**.**

Stage 3

Title: Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

Overview

In the modern digital environment, organizations increasingly depend on cloud computing, mobile devices, and remote work models to conduct daily operations. While these technologies improve productivity and flexibility, they also introduce new security challenges. Traditional security models relied on a fixed network perimeter where users inside the network were automatically trusted. However, with employees accessing systems from multiple devices, locations, and networks, this model has become ineffective and vulnerable to cyber threats.

To address these challenges, organizations are adopting advanced security frameworks that focus on verifying every access request before granting access to sensitive resources. One such approach is context-aware access control, which evaluates different contextual factors related to the user and the environment. Instead of relying only on usernames and passwords, this system considers information such as the user's identity, the security status of the device being used, the geographic location of the user, and the risk level of the application being accessed.

This project focuses on the design and implementation of a context-aware access control system that improves security by making intelligent access decisions based on real-time contextual data. The system analyzes multiple factors to determine whether a user should be granted access, restricted access, required to complete additional authentication, or completely blocked. By implementing this approach, organizations can significantly reduce unauthorized access, protect sensitive data, and ensure secure operations in modern distributed environments.

Identity

Identity is one of the most important factors in access control systems. It refers to the process of verifying and identifying the user who is attempting to access an application, network, or resource. Proper identity verification ensures that only authorized individuals can access sensitive organizational information.

In context-aware access control systems, identity verification goes beyond basic username and password authentication. Additional identity attributes such as user roles, job responsibilities, department, and access permissions are also considered. For example, an administrator may have higher access privileges compared to a regular employee.

Modern identity systems also integrate multi-factor authentication (MFA) to provide an additional layer of security. MFA requires users to provide more than one form of verification, such as a password and a one-time verification code. By combining identity verification with contextual analysis, the system can ensure that access is granted only to legitimate users with proper authorization.

Device Posture

Device posture refers to the overall security condition or health status of the device that a user is using to access organizational resources. Since users may connect from different devices such as laptops, smartphones, or tablets, it is important to verify that these devices meet the organization’s security standards before granting access.

A device posture check evaluates various factors such as whether the device has the latest operating system updates, whether antivirus software is installed and active, whether disk encryption is enabled, and whether the device is managed by the organization's IT department. These checks help determine whether the device is secure enough to access sensitive applications.

For example, a company-managed laptop with updated security patches may be considered a trusted device, while an unknown personal device without proper security controls may be considered high risk. Based on the device posture evaluation, the system can decide to allow access, limit functionality, or request additional authentication to reduce potential risks.

Application Risk

Different applications within an organization have different levels of sensitivity and importance. Some applications may only contain general information, while others may store confidential business data, financial records, or personal information. Therefore, the level of security required for each application should vary according to its risk level.

Application risk assessment helps determine the potential impact if a particular application is compromised. High-risk applications such as financial systems, administrative portals, or confidential databases require stronger security measures. In such cases, the access control system may enforce strict policies such as multi-factor authentication, restricted access permissions, or limited session durations.

On the other hand, low-risk applications may allow easier access for authorized users. By evaluating application risk, the system ensures that security controls are applied appropriately based on the sensitivity of the data being accessed.

Context-Aware Access

Context-aware access is a modern security approach that evaluates multiple contextual factors before granting access to applications or data. Instead of making static decisions based only on login credentials, this approach continuously analyzes contextual information such as user identity, device posture, geographic location, time of access, and application risk level

The system uses these contextual signals to make dynamic access decisions in real time. For example, if a trusted employee logs in from a secure company device within the office network, the system may allow seamless access to applications. However, if the same user attempts to access a critical system from an unknown device or an unusual location, the system may require additional authentication or deny access altogether.

This adaptive approach significantly improves organizational security by reducing the risk of unauthorized access and preventing potential cyberattacks. At the same time, it ensures a smooth and efficient user experience for legitimate users. By implementing context-aware access control, organizations can build a secure and flexible access management framework suitable for modern digital workplaces.

Conclusion:

Stage 1:

In conclusion, web application testing is a crucial process that ensures the security,functionality, and reliability of web-based software. It involves a comprehensive evaluation of various aspects, including user interface, functionality, performance, and security to identify and rectify issues before they impact end-users. This process not only enhances the quality of web applications but also bolsters their resilience against potential threats and vulnerabilities. In an age where online services and applications are integral to our daily lives, effective web application testing is essential to deliver a seamless and secure user experience.

Stage 2:

The Nessus report for the specific website has highlighted key security insights. It identified vulnerabilities, categorized by severity, with a focus on critical and high-risk issues that need immediate attention. Recommendations for addressing these vulnerabilities include patching, reconfiguration, and other security measures, with a priority on actions that can have the most significant impact. Compliance with industry standards and best practices is considered, ensuring alignment with recognized security benchmarks like OWASP guidelines. The report underscores the need for continuous monitoring, regular updates, and ongoing security efforts to maintain a strong security posture. In summary, the Nessus report offers a clear view of the website's security state, provides guidance on mitigating vulnerabilities, and stresses the importance of sustained vigilance against evolving threats.

Stage 3:

The implementation of Zscaler Private Access marks a pivotal shift from a vulnerable, network-centric security model to a resilient, identity-centric Zero Trust architecture. By enforcing least-privilege access and rendering private applications invisible to the internet, this project effectively neutralizes the threats of lateral movement and network-based attacks. The solution not only fortifies the organization's security posture against modern cyber threats but also delivers a seamless and high-performance experience for a distributed workforce. Furthermore, the decoupling of access from the network simplifies IT operations, reduces dependency on

legacy VPN infrastructure, and provides granular visibility into user-application interactions. Ultimately, this initiative establishes a future-ready foundation for secure digital transformation..

Future Scope:

Stage 1: future scope of web application testing

The future scope of web application testing is promising and evolving rapidly, driven by the continuous growth of the internet and web-based applications.

Here are some key aspects of its future scope:

▪ **Increased Demand:** As more businesses and services move online, the demand for web applications continue to grow. This, in turn, increases the demand for web application testing to ensure security, reliability, and functionality.
▪ **Advanced Technologies:** The complexity of web applications is rising with the integration of advanced technologies like AI, IoT, and blockchain. Testing these cutting-edge applications will require specialized skills and tools.
▪ **Security Emphasis:** With the growing number of cyber threats and data breaches, security testing for web applications will become even more critical. Testers will need to focus on vulnerabilities, data protection, and compliance with regulations like GDPR.
▪ **Mobile and Cross-Browser Testing:** Mobile usage is on the rise, and web applications must be
responsive and functional on various devices and browsers. Testing for cross-compatibility will be essential.
▪ **Performance Testing:** As user expectations for speed and performance increase, load testing, stress testing, and other performance testing types will be crucial to ensure web applications can handle traffic spikes.

Stage 2: future scope of the testing process you understood.

The future scope of the web application testing process, particularly in terms of identifying vulnerabilities, is exceedingly promising due to the continuous growth of digital platforms, the escalating importance of cybersecurity, and the ever-evolving threat landscape. Here are some key aspects that highlight the prospective scope of web application testing for vulnerability discovery:

▪ **AI-Driven Testing**: The integration of artificial intelligence (AI) and machine learning (ML) into web application testing tools will revolutionize the way vulnerabilities are identified. AI algorithms can swiftly scan vast amounts of code and data to pinpoint vulnerabilities that might elude human testers.

▪ **IoT and Mobile App Testing**: With the proliferation of Internet of Things (IoT) devices and the increasing usage of mobile applications, the scope of web application testing will extend to encompass these areas. Ensuring the security of IoT devices and the interfaces they use will become critical.

▪ **Blockchain and Cryptocurrency Security:** As blockchain technology and cryptocurrencies continue to gain traction, security testing will be imperative to safeguard transactions and digital assets. Ensuring the robustness of blockchain-based applications will be a specialized niche in web application testing. Serverless Architectures: With the adoption of serverless computing, web application testing will need to adapt to assess the security of serverless functions and APIs. Ensuring that serverless components are free from vulnerabilities will be paramount.

▪ **Container Security**: As containerization technologies like Docker and Kubernetes become ubiquitous, web application testing will extend to cover container security. This includesensuring that container images and orchestration configurations are free from vulnerabilities.

Stage 3: future scope of Aware Access Control

The successful deployment of ZPA lays the groundwork for a broader, more integrated security ecosystem. Future enhancements can be explored to further mature the organization's security capabilities:

▪ **Integration with Zscaler Internet Access (ZIA):** Converging Private Access (ZPA) with Internet
Access (ZIA) to create a unified Secure Access Service Edge (SASE) platform, managing all web and private traffic through a single policy framework.

▪ **Advanced Device Posture Checking:** Moving beyond basic compliance to incorporate real-time
risk scores from EDR tools, blocking access if a device shows signs of active compromise.

▪ **Privileged Remote Access:** Extending ZPA to third-party vendors and contractors with time-bound, audited access to specific critical systems, replacing jump boxes and bastion hosts.

▪ **IoT/OT Segmentation**: Applying the same micro-tunneling principles to Internet of Things (IoT) and Operational Technology (OT) devices to ensure they can only communicate with specific management servers.

▪ **AI-Driven Anomaly Detection:** Leveraging machine learning on ZPA logs to detect behavioral
anomalies, such as a user accessing an application at an unusual hour or from a strange location, triggering automated MFA challenges or access revocation.

▪ **Cloud Workload Protection:** Utilizing ZPA to secure connections between containers and microservices in multi-cloud environments (AWS, Azure, GCP), ensuring east-west traffic between workloads is encrypted and authenticated.

▪ **Automated Provisioning/Deprovisioning**: Enhancing the identity provider integration to automatically revoke application access the moment an employee is terminated or changes roles, ensuring near real-time access control.

▪ **Digital Experience Monitoring (DEM):** Implementing DEM tools to proactively monitor the end-user experience, identifying network latency or application performance issues before they impact productivity.

Topics Explored:

1. Owasp top 10
2. Scanning
3. Vulnerability
4. Awareness
5. Identity

Tools Explored:

1. Nessus Scanner
2. Owasp
3. https://testphp.vulnweb.com/